

Tasks:

1. **Open Burp Suite.**
2. **Visit a practice website or your own application.**
3. **Capture the following requests:**
 - **Homepage Request**
 - **Login Page Request**
 - **Login Request**
 - **Logout Request**
4. **Identify:**
 - **Request Method**
 - **Response Code**
 - **Cookies**
 - **Session ID**
 - **Parameters**
5. **Compare the following:**
 - **Before Login**
 - **After Login**
6. **Find answers to:**
 - **What changes after login?**
 - **Which cookie is responsible for maintaining the session?**
 - **What happens when you logout?**
 - **Does the session cookie change after login?**
7. **Send Login Request to Repeater and analyze:**
 - **Headers**
 - **Cookies**
 - **Parameters**
 - **Response**
8. **Create a Login Flow Diagram:**

Browser → Login Request → Server → Session Creation → Logged In User

Assignment:

Prepare a report containing:

1. **What is Authentication?**
2. **What is Authorization?**
3. **What is a Session?**

- 4. What is a Cookie?**
- 5. Difference between Authentication and Authorization.**
- 6. Difference between Session Cookies and Persistent Cookies.**
- 7. Screenshots of:**
 - **Login Request**
 - **Login Response**
 - **Session Cookie**
 - **Logout Request**

Analyze the login flow of:

- **Gmail**
- **Facebook**
- **Instagram**
- **Amazon**

Observe:

- **Login page**
- **Password page**
- **Verification page**
- **Security features used**

Submission:

PDF or Word Document with screenshots and observations.

Aim

To analyze the authentication mechanism, session management, cookies, login requests, logout requests, and authorization process of a web application using Burp Suite.

Objective

1. Capture HTTP requests and responses.
2. Analyze login and logout functionality.
3. Identify session cookies.
4. Understand authentication and authorization mechanisms.
5. Compare user state before and after login.
6. Use Burp Repeater to inspect requests.
7. Study login flows of popular websites.
8. Understand session management techniques.

Software Required

- Burp Suite Community Edition
- Google Chrome / Burp Browser
- Internet Connection
- Practice Website

Examples:

- PortSwigger Web Security Academy
- Amazon
- Facebook
- Instagram
- Gmail

PART A – BURP SUITE CONFIGURATION

Step 1: Open Burp Suite

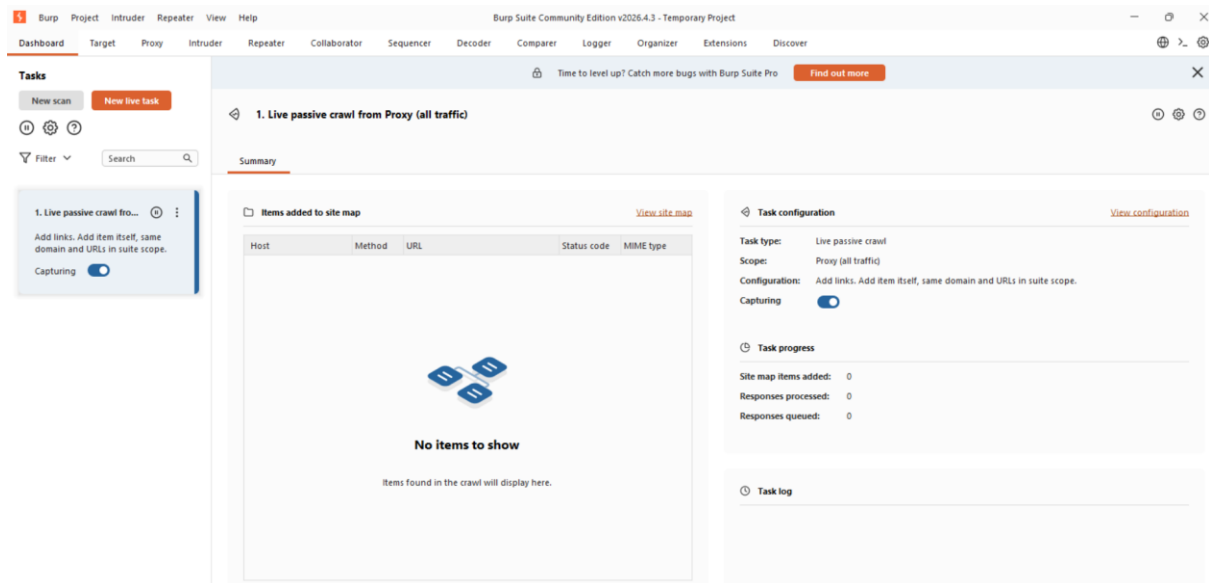
Launch Burp Suite.

You will see:

- Dashboard
- Proxy
- Intruder
- Repeater
- Decoder
- Comparer

Screenshot :

Burp Suite Home Screen



Step 2: Open Burp Browser

Navigate:

Proxy → Intercept → Open Browser

A Chromium browser will open with Burp proxy preconfigured.

PART B – HOMEPAGE REQUEST ANALYSIS

Step 3: Visit Website

Example: Portswigger labs

Homepage loads.

Step 4: Locate Homepage Request

Navigate:

Proxy → HTTP History

Look for:

GET /

or

GET /index

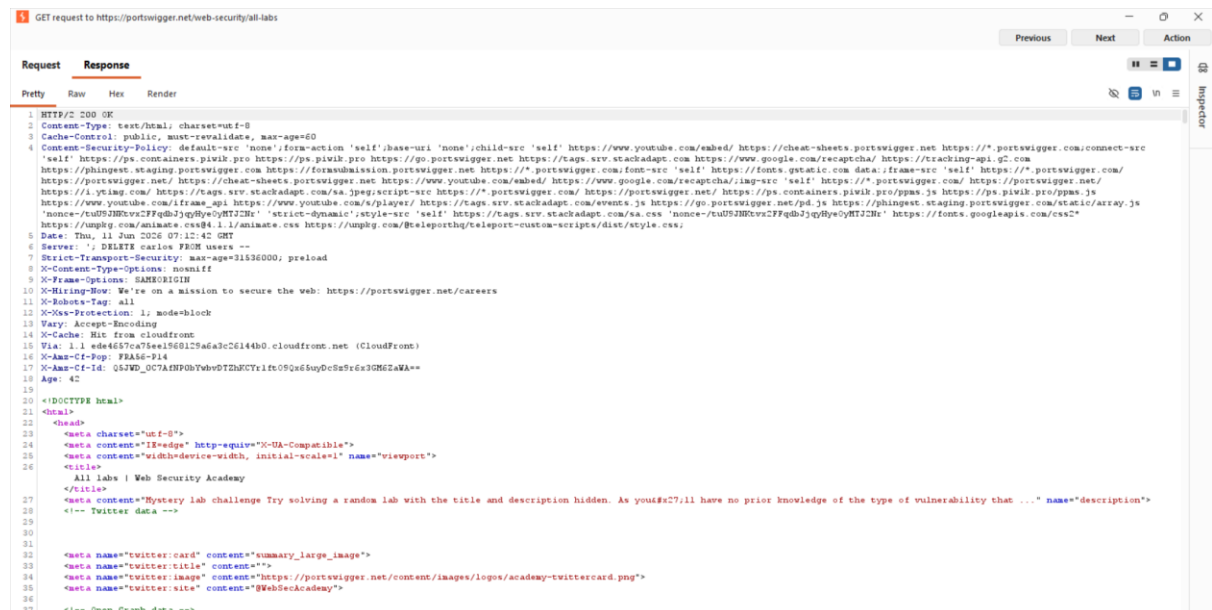
Screenshot :

Homepage Request



Screenshot :

Homepage Response



Homepage Analysis

Request Method

GET

Purpose

Used to retrieve webpage content from server.

Response Code

200 OK

Meaning

Request processed successfully.

Cookies

Visitor id:1066743

Parameters

Usually none.

Request cookies			15	^
Name	Value			
_pk_id.287552c2-4917-42e...	d2774aec68b42488.17809...	>		
_gcl_au	1.1.894481015.1780988013	>		
sa-r-source	www.google.com	>		
sa-r-date	2026-06-09T06:53:33.028Z	>		
sa-user-id	s%3A0-98d336dc-b676-50...	>		
sa-user-id-v2	s%3AmNM23LZ2UDVe6B8...	>		
sa-user-id-v3	s%3AAQAKIDgs5spEQHGj...	>		
sa-user-id-v4	s%3A.o6W7wkJsHSTU4%2...	>		
visitor_id1066743	685026762	>		
visitor_id1066743-hash	cdc5fc26594ba9a0013fa86...	>		
AWSALBAPP-0	_remove_	>		
AWSALBAPP-1	_remove_	>		
AWSALBAPP-2	_remove_	>		
AWSALBAPP-3	_remove_	>		
ph_phc_zmnmWxifkm9TH...	{"\$device_id":"019eab28-6...	>		

PART C – LOGIN PAGE REQUEST ANALYSIS

Step 5: Open Login Page

Click:

Login

Sign In

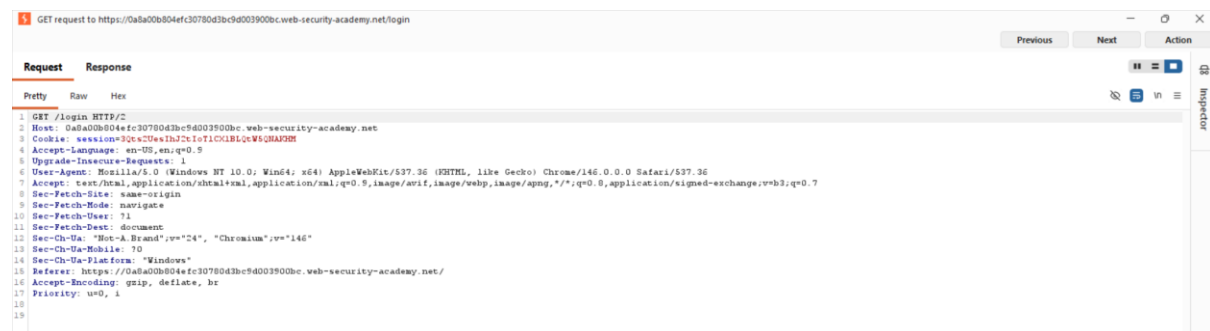
Burp captures new request.

Example

GET /login HTTP/2

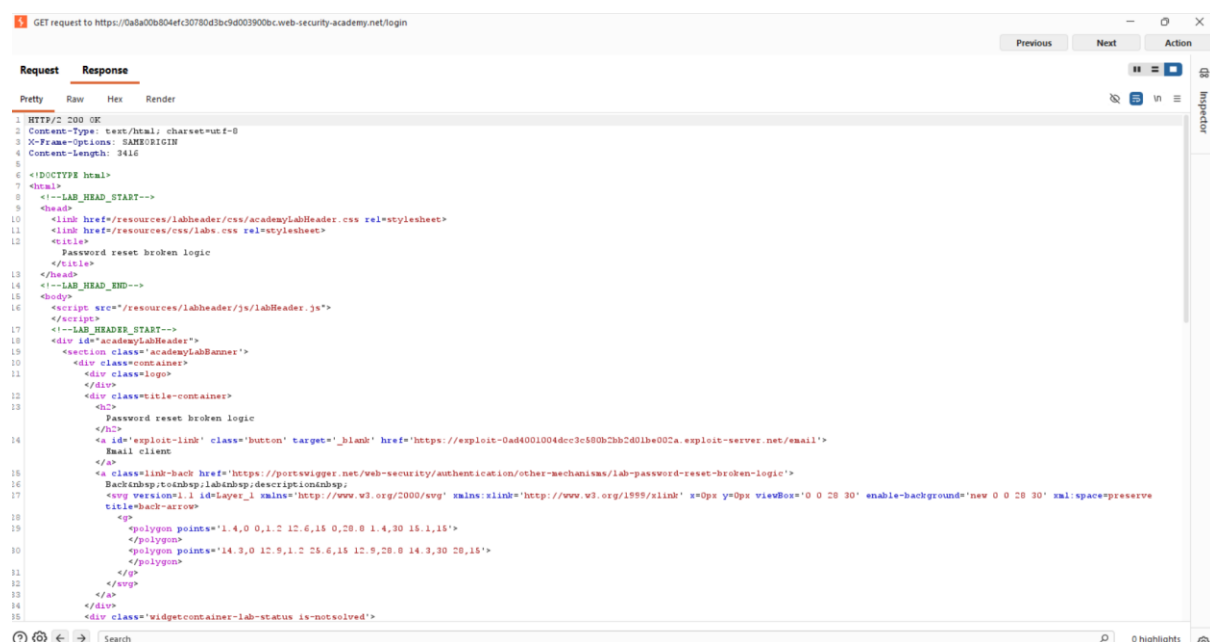
Screenshot 5

Login Page Request



Screenshot 6

Login Page Response



Analysis

Method

GET

Purpose

Request login page.

Response

200 OK

Data Returned

- HTML Form
- Username field
- Password field

PART D – LOGIN REQUEST ANALYSIS

Step 6: Enter Credentials

Example:Username: testuser@gmail.com

Password: Password123

Click Login.

Request Captured

- POST /login HTTP/2
- username= testuser@gmail.com
- password=Password123

Screenshot 7

Login Request Highlight:

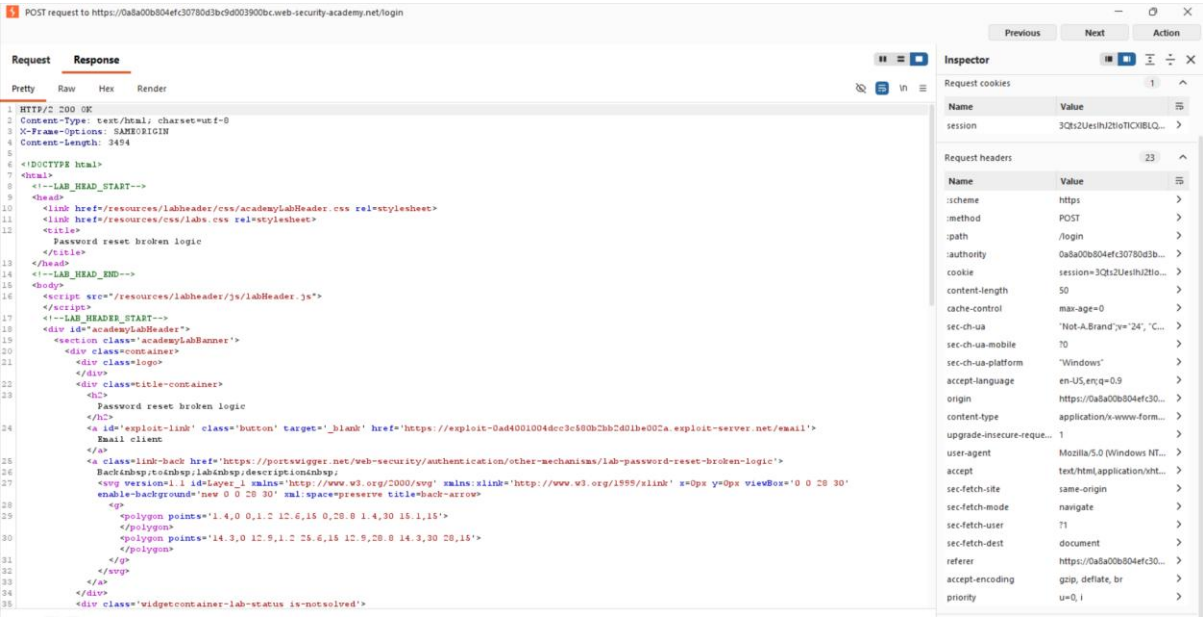
- POST
- Username
- Password

The screenshot displays the 'Request' tab in a web browser's developer tools. The request is a POST to the URL `https://0a8a00b04efc30780d3bc9d003900bc.web-security-academy.net/login`. The 'Request' pane shows the raw request details, including headers and body parameters. The 'Inspector' pane on the right shows the 'Request attributes' section, which includes the protocol (HTTP/2), method (POST), and path (/login). Below this, the 'Request body parameters' section shows the username (testuser@gmail.com) and password (Password123). The 'Request cookies' section shows no cookies. The 'Request headers' section shows 23 headers, and the 'Response headers' section shows 3 headers.

```
1 POST /login HTTP/2
2 Host: 0a8a00b04efc30780d3bc9d003900bc.web-security-academy.net
3 Cookie: session=3Qcs2Ues1bJ2c1oT1CK1BLQcW5Q8A92H
4 Content-Length: 50
5 Cache-Control: max-age=0
6 Sec-Ch-UA: "Not-A.Brand",v="24", "Chromium",v="146"
7 Sec-Ch-UA-Mobile: 70
8 Sec-Ch-UA-Platform: "Windows"
9 Accept-Language: en-US,en;q=0.9
10 Origin: https://0a8a00b04efc30780d3bc9d003900bc.web-security-academy.net
11 Content-Type: application/x-www-form-urlencoded
12 Upgrade-Insecure-Requests: 1
13 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
14 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-Mode: navigate
17 Sec-Fetch-User: 1
18 Sec-Fetch-Dest: document
19 Referer: https://0a8a00b04efc30780d3bc9d003900bc.web-security-academy.net/login
20 Accept-Encoding: gzip, deflate, br
21 Priority: u=0, i
22
23 username=testuser40@gmail.com&password=Password123
```


Screenshot 8

Login Response



Detailed Analysis

Method

POST

Why POST?

Sensitive information is sent securely in request body.

Parameters Found

Parameter	Purpose
username	User identification
password	Authentication

Response Code

Usually:

200 OK

Meaning

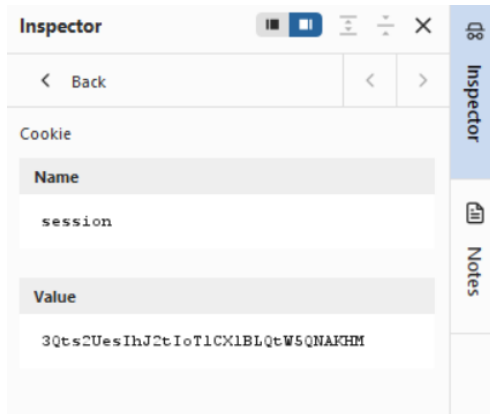
User successfully authenticated.

PART E – SESSION COOKIE ANALYSIS

Step 7: Locate Set-Cookie Header

Look at Login Response.

Screenshot :Session Cookie=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM



Analysis

What Happened?

Server created a session.

Purpose

Uniquely identifies logged-in user.

Importance

Without session cookie:

- User becomes anonymous
- Protected pages inaccessible

PART F – BEFORE LOGIN VS AFTER LOGIN

Before Login

Request:

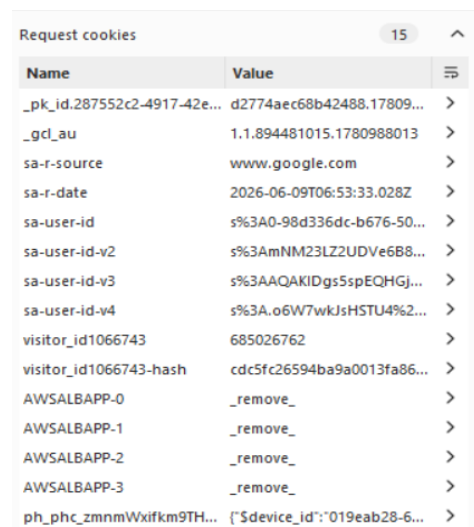
GET /

Cookie:

visitor=1066743

Screenshot :

Before Login Cookies



A screenshot of a web browser's developer tools, specifically the 'Request cookies' tab. It displays a list of 15 cookies. The cookies include identifiers like _pk_id, _gcl_a, sa-r-source, sa-r-date, sa-user-id, and visitor_id, along with various session and application cookies like AWSALBAPP and ph_phc. Each row shows the cookie name, its value, and a right-pointing arrow icon.

Name	Value
_pk_id.287552c2-4917-42e...	d2774aec68b42488.17809...
_gcl_a	1.1.894481015.1780988013
sa-r-source	www.google.com
sa-r-date	2026-06-09T06:53:33.028Z
sa-user-id	s%3A0-98d336dc-b676-50...
sa-user-id-v2	s%3AmNM23LZ2UDVe6B8...
sa-user-id-v3	s%3AAQAKIDgs5spEQHGj...
sa-user-id-v4	s%3A.o6W7wkJsHSTU4%2...
visitor_id1066743	685026762
visitor_id1066743-hash	cdc5fc26594ba9a0013fa86...
AWSALBAPP-0	_remove_
AWSALBAPP-1	_remove_
AWSALBAPP-2	_remove_
AWSALBAPP-3	_remove_
ph_phc_zmnWxifkm9TH...	{ "\$device_id": "019eab28-6...

After Login

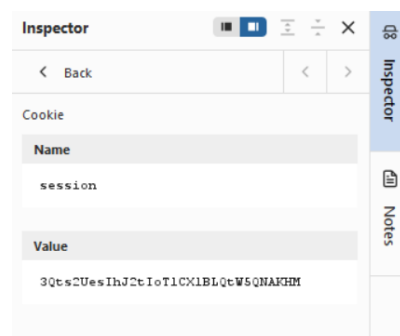
Request:

GET /my-account

Cookie: session=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM

Screenshot :

After Login Cookies



A screenshot of a web browser's developer tools, specifically the 'Inspector' tab. It shows a single cookie named 'session' with a value that is a long alphanumeric string. The interface includes a 'Back' button, a search bar, and a 'Notes' sidebar.

Name	Value
session	30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM

Comparison Table

Feature	Before Login	After Login
Authentication Status	Not Authenticated	Authenticated
Session Cookie	Not Present	session
Session ID	None	30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM
User Access	Public Pages	Account Pages
User Identity	Unknown	Verified
Server Session	Not Created	Created

Questions and Answers

Q.What changes after login?

ANS.After successful authentication:

1. Server validates username and password.
2. A new session is created.
3. Session cookie (session) is assigned to the browser.
4. User becomes authenticated.
5. Protected resources become accessible.
6. Every subsequent request contains the session cookie.

Q.Which cookie maintains the session?

ANS.session=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM.This cookie maintains the user's session.

Q.Does session cookie change after login?

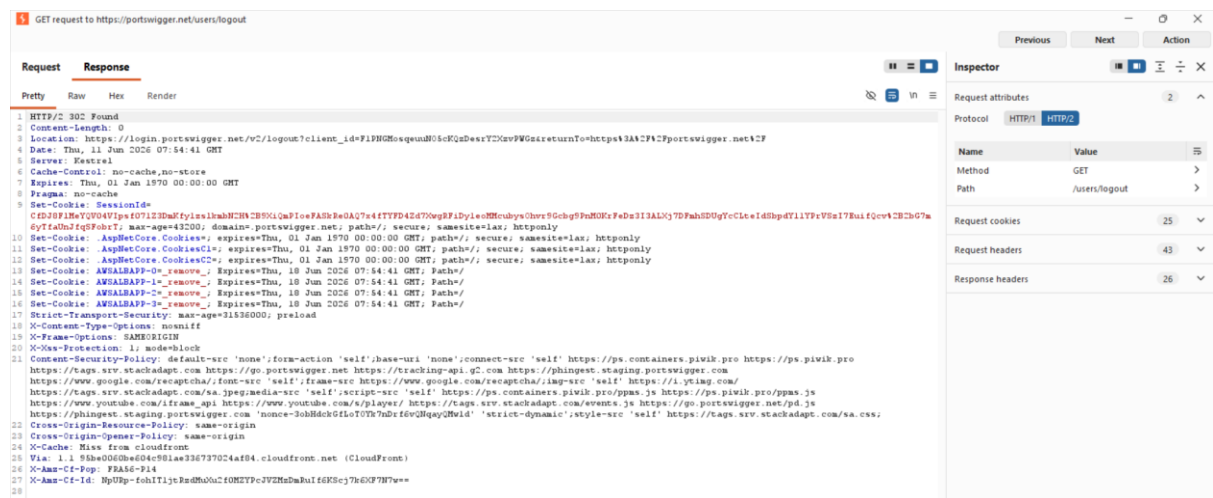
ANS.Yes.

Before login, there was no authenticated session cookie visible.

After successful login, the application generated a new session cookie:

session=30ts2UesIhJZtIoT1CX1BLQtW5QNAKHM

This new session ID is used to maintain the authenticated session. Many web applications intentionally generate a fresh session ID after login to prevent **Session Fixation attacks** and improve security.



Analysis

What Happens?

Server:

1. Invalidates session.
2. Deletes session record.
3. Redirects user to homepage.

Example Response

Set-Cookie:

session=deleted

Q.What happens after logout?

ANS:User:

- Loses authenticated status
- Must login again
- Cannot access protected pages

PART H – REPEATER ANALYSIS

Step 9: Send Login Request to Repeater

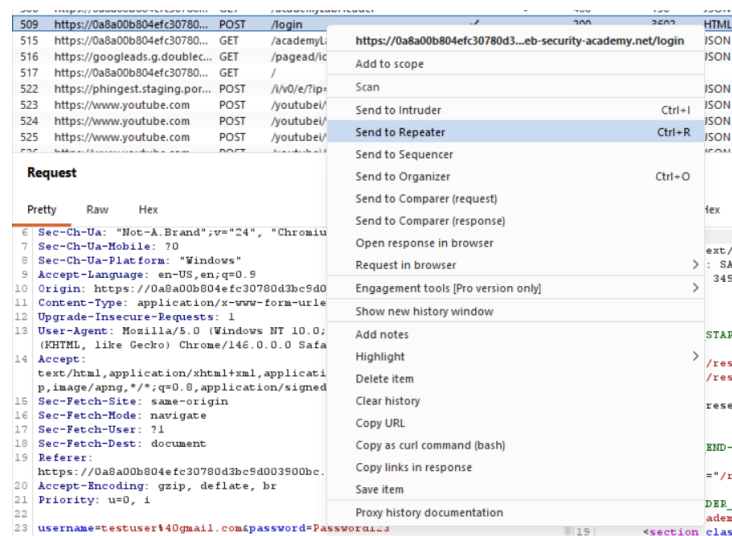
Right click Login Request.

Select:

Send to Repeater

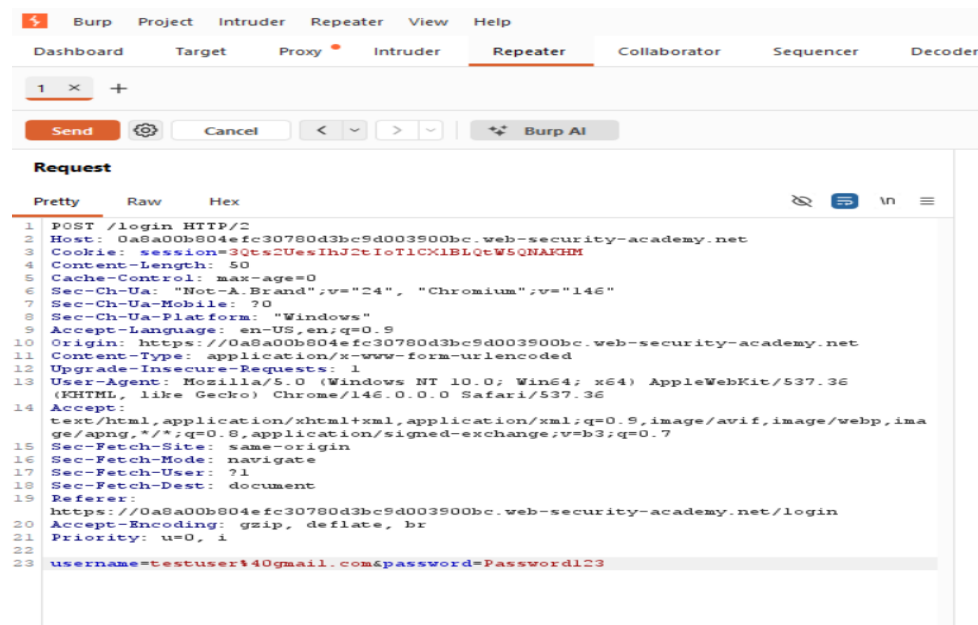
Screenshot :

Send To Repeater



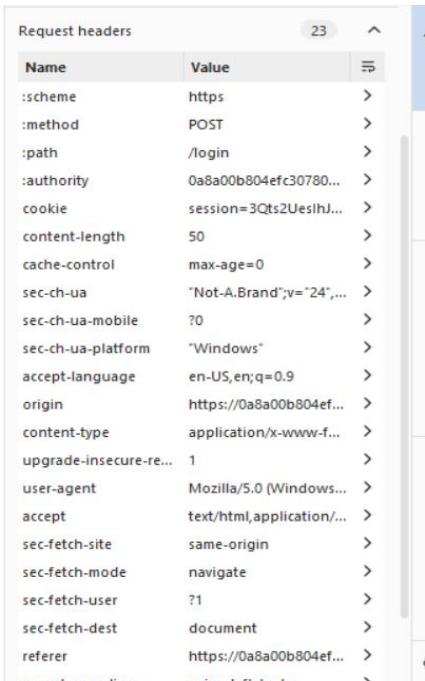
Step 10: Analyze Request

Screenshot :Repeater Request



Headers Analysis

SCREENSHOT:

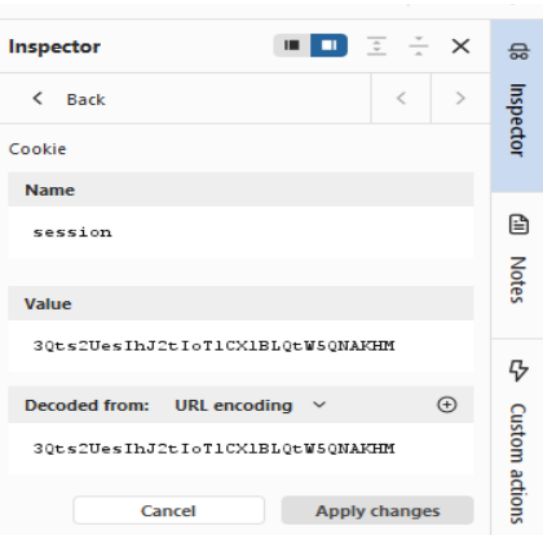


A screenshot of the 'Request headers' section in a web browser's developer tools. It shows a list of 23 headers with their names and values. The headers include standard HTTP headers like :scheme, :method, :path, :authority, cookie, content-length, cache-control, sec-ch-ua, sec-ch-ua-mobile, sec-ch-ua-platform, accept-language, origin, content-type, upgrade-insecure-re..., user-agent, accept, sec-fetch-site, sec-fetch-mode, sec-fetch-user, sec-fetch-dest, and referer.

Name	Value
:scheme	https
:method	POST
:path	/login
:authority	0a8a00b804efc30780...
cookie	session=3Qts2UeslhJ...
content-length	50
cache-control	max-age=0
sec-ch-ua	"Not-A.Brand";v="24",...
sec-ch-ua-mobile	?0
sec-ch-ua-platform	"Windows"
accept-language	en-US,en;q=0.9
origin	https://0a8a00b804ef...
content-type	application/x-www-f...
upgrade-insecure-re...	1
user-agent	Mozilla/5.0 (Windows...
accept	text/html,application/...
sec-fetch-site	same-origin
sec-fetch-mode	navigate
sec-fetch-user	?1
sec-fetch-dest	document
referer	https://0a8a00b804ef...

Cookie Analysis

Screenshot:



A screenshot of the 'Inspector' panel in a web browser's developer tools, specifically the 'Cookie' section. It shows a single cookie with the name 'session' and a value '3Qts2UeslhJ2tIoT1CX1BLQtW5QNAKHM'. The 'Decoded from' dropdown is set to 'URL encoding'. There are 'Cancel' and 'Apply changes' buttons at the bottom.

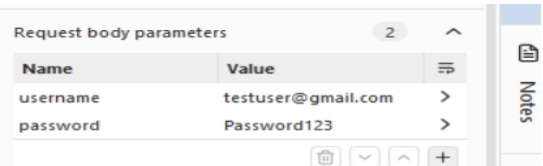
Name	Value
session	3Qts2UeslhJ2tIoT1CX1BLQtW5QNAKHM

Decoded from: URL encoding

Cancel Apply changes

Parameter Analysis

Screenshot:



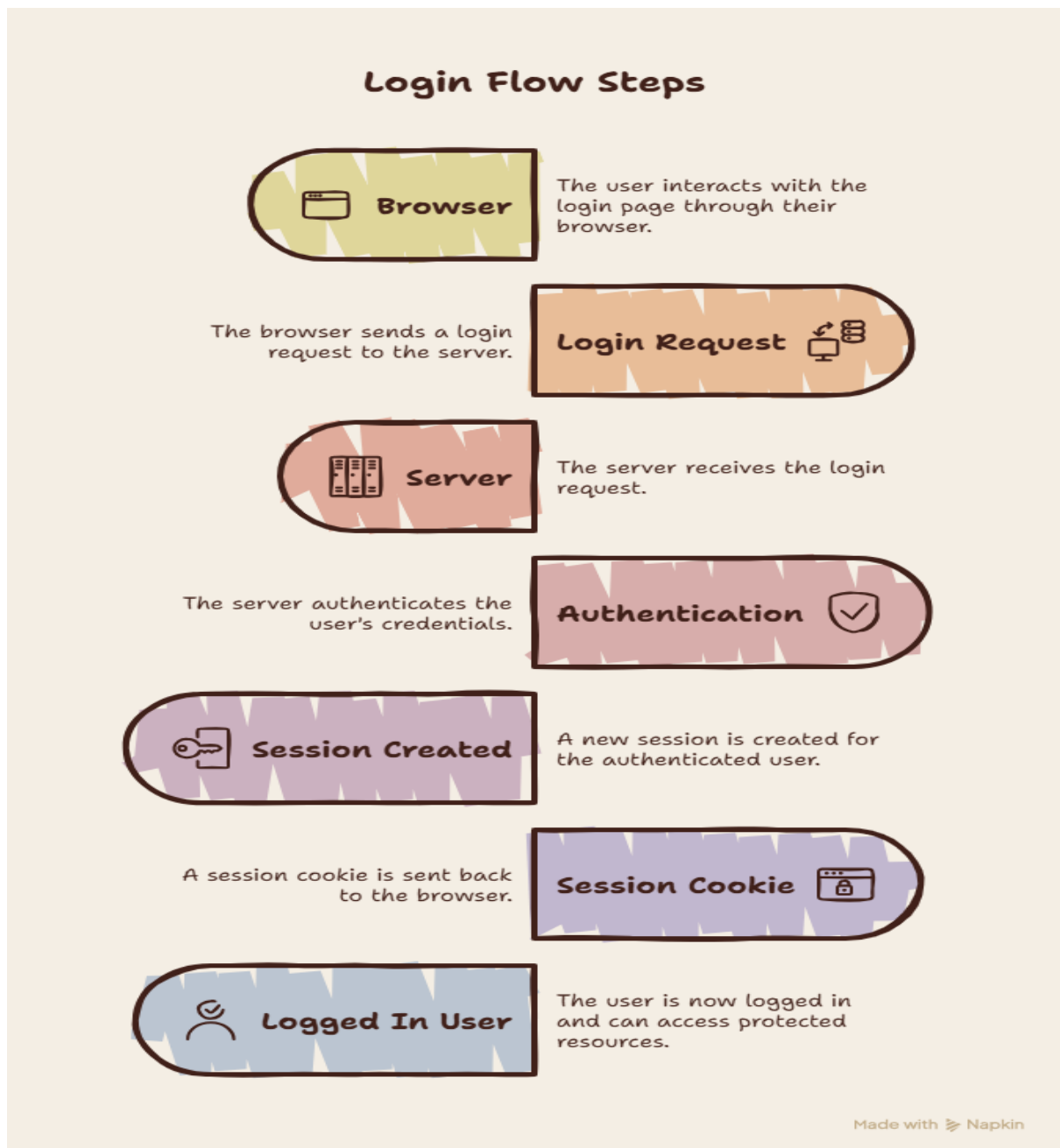
A screenshot of the 'Request body parameters' section in a web browser's developer tools. It shows two parameters: 'username' with the value 'testuser@gmail.com' and 'password' with the value 'Password123'.

Name	Value
username	testuser@gmail.com
password	Password123

Response Analysis

Request attributes 2 ^		
Protocol	HTTP/1 HTTP/2	
Name	Value	
Method	POST	>
Path	/login	>

LOGIN FLOW DIAGRAM



THEORY SECTION

Authentication

Authentication is the process of verifying the identity of a user before granting access to resources.

Examples:

- Username and Password
- OTP
- Biometrics

Authorization

Authorization determines what actions an authenticated user is permitted to perform.

Example:

Admin:

- Add Users
- Delete Users

Normal User:

- View Data Only

Session

A session is a temporary server-side storage mechanism used to maintain user state between multiple requests.

Cookie

A cookie is a small piece of data stored in the browser and sent with every request to the server.

Authentication vs Authorization

Authentication	Authorization
Identity Verification	Permission Verification
First Step	Second Step
Login Process	Access Control
Username & Password	Roles & Permissions

Session Cookie vs Persistent Cookie

Session Cookie	Persistent Cookie
Temporary	Permanent
Deleted on Browser Close	Stored Until Expiry
Authentication Purpose	Remember User
Memory Storage	Disk Storage

LOGIN FLOW ANALYSIS OF POPULAR WEBSITES

Gmail

Login Flow

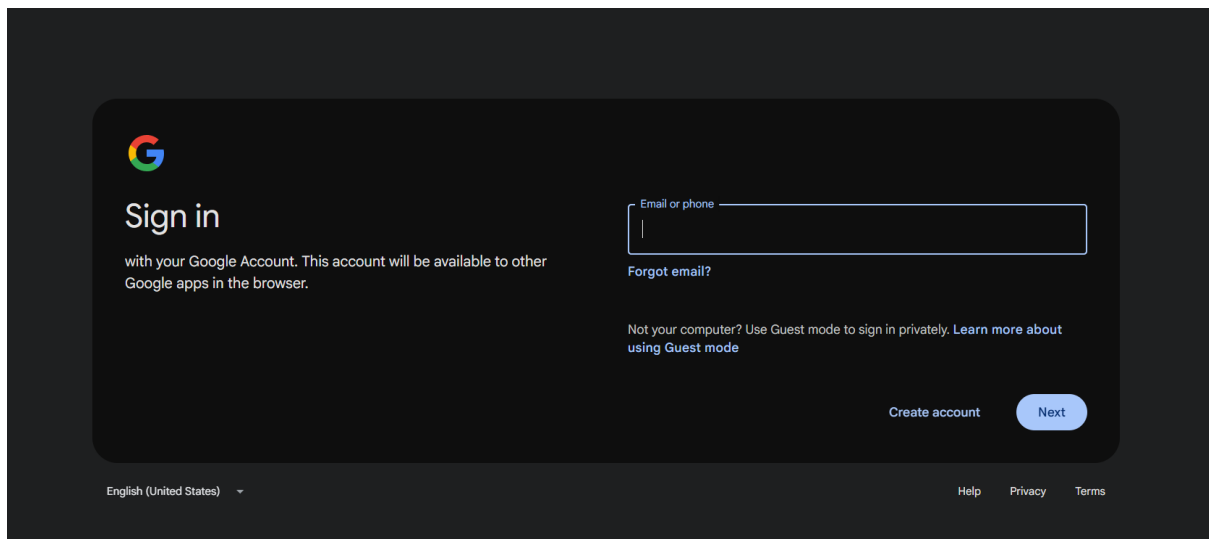
1. Enter Email
2. Click Next
3. Enter Password
4. MFA Verification
5. Access Mailbox

Security Features

- Two-Factor Authentication
- Device Recognition
- Suspicious Login Detection

Screenshot :

Gmail Login Page



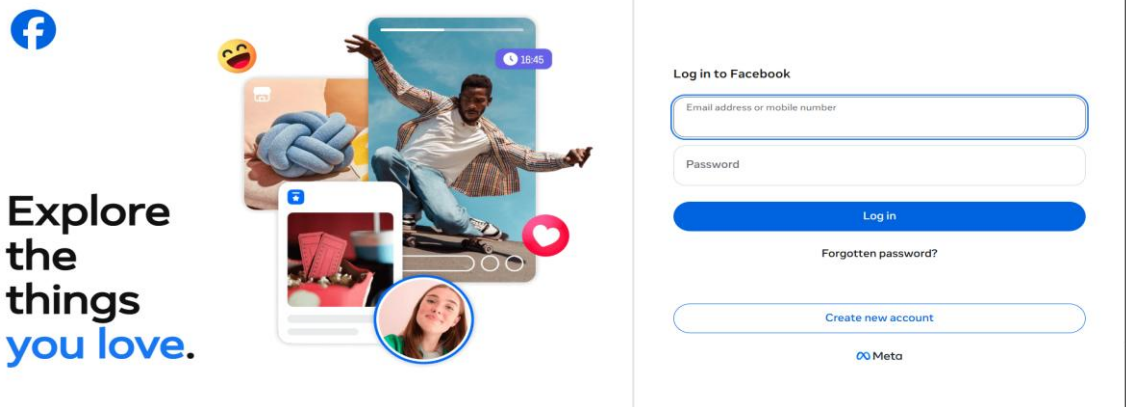
Facebook

Security Features

- OTP Verification
- Login Alerts
- Device Verification
- 2FA

Screenshot :

Facebook Login Page



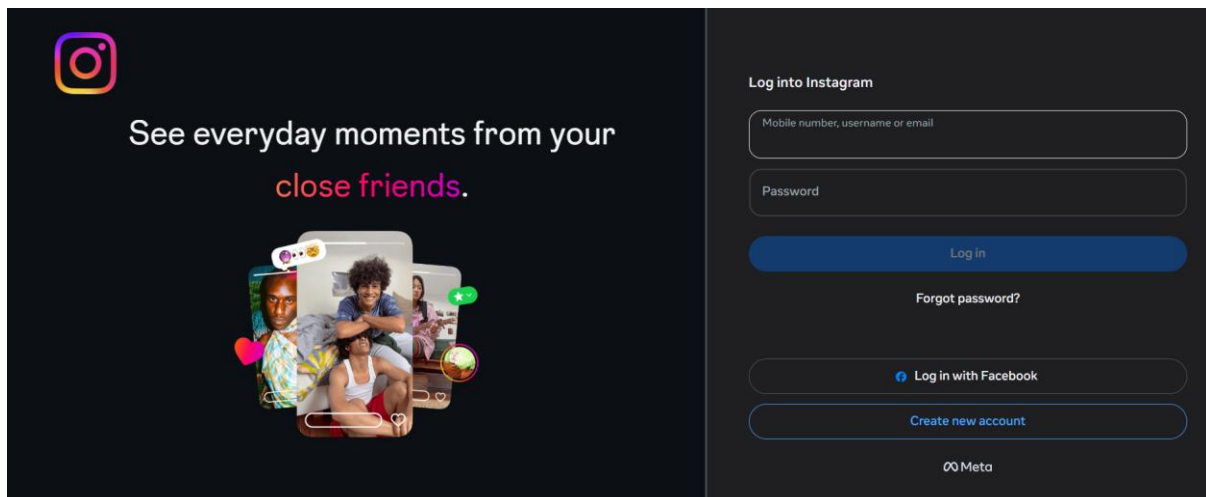
Instagram

Security Features

- OTP Verification
- Login Activity Monitoring
- Two-Factor Authentication

Screenshot :

Instagram Login Page



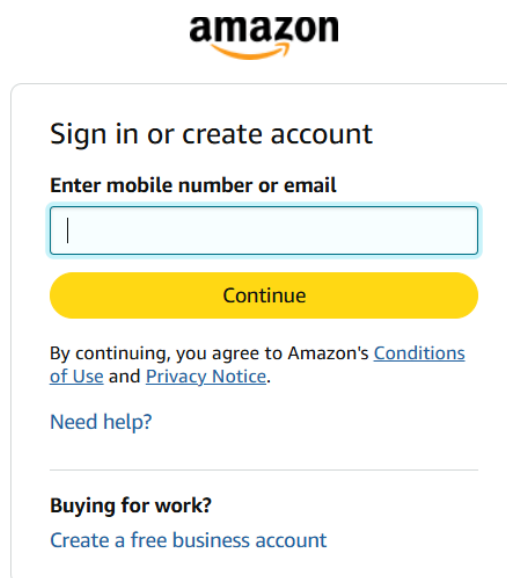
Amazon

Security Features

- Multi-Factor Authentication
- OTP Verification
- Fraud Detection System
- Device Recognition

Screenshot:

Amazon Login Page



The screenshot shows the Amazon login interface. At the top is the Amazon logo. Below it is a white box with rounded corners containing the text 'Sign in or create account'. Underneath is the prompt 'Enter mobile number or email' followed by a text input field. A yellow 'Continue' button is positioned below the input field. Further down, there is a line of text stating 'By continuing, you agree to Amazon's [Conditions of Use](#) and [Privacy Notice](#).' Below this is a link for 'Need help?'. At the bottom of the box, there is a section titled 'Buying for work?' with a link to 'Create a free business account'.

Conclusion

The experiment successfully demonstrated the working of authentication, authorization, sessions, and cookies using Burp Suite. Login and logout requests were captured and analyzed. Session cookies responsible for maintaining user authentication were identified. Burp Repeater was used to inspect requests and responses, and the login flows of major web applications were studied to understand modern web security mechanisms.